Enterprise AI Governance & Ethics Handbook

Document Version: 2.4 | Classification: Restricted Internal | Effective: Q4 2024

Section 1: Executive Summary and Scope

This policy governs all machine learning models, generative AI applications, and autonomous agents deployed across Datheon enterprise infrastructure. All models interacting with customer data or operational decision systems must be cataloged in the Datheon Central Model Registry prior to staging deployment.

Section 2: Model Registration and Lineage Tracking

Every production LLM prompt pipeline must retain immutable audit logs containing prompt templates, model versions, temperature parameters, and completion timestamps. The mandatory retention period for inference metadata is 365 days. Engineering teams must submit a Model Risk Assessment (MRA-Form-101) to the AI Ethics Board before production release.

Section 3: Data Privacy, Redaction, and PII Protection

Direct ingestion of Personally Identifiable Information (PII) into public LLM endpoints is strictly prohibited. All incoming user prompts must traverse the PII Masking Gateway (Datheon SafeGuard Engine) which automatically replaces Social Security Numbers, credit card numbers, and patient health identifiers with cryptographic tokens.

Data retention on third-party cloud LLM providers must be contractually configured to zero-day retention (ZDR). Model training on proprietary corporate customer datasets requires explicit bilateral consent from the Legal & Compliance Department.

Section 4: Bias Mitigation & Demographic Parity

Automated evaluation suites must assess LLM outputs against standard demographic parity and disparate impact metrics. Any pipeline demonstrating adverse impact ratios below 0.80 across protected classes will trigger an automated deployment freeze.

Section 5: Human-in-the-Loop (HITL) Thresholds

For financial transactions exceeding $10,000 USD or automated hiring recommendations, autonomous decisioning is prohibited. A qualified human reviewer must review and countersign the decision within 24 hours. If model confidence falls below 85% (confidence score < 0.85), the query must be automatically escalated to Level 2 support.

Section 6: Incident Reporting and Escalation SLA

Any critical LLM security incident - such as prompt injection exploits, jailbreaks, or unauthorized data exfiltration - must be reported to the Datheon Cyber Defense Operations Center (CDOC) within 60 minutes of detection. Severity-1 incidents trigger immediate revocation of model API keys and dynamic failover to deterministic fallback services.

Section 7: Compliance Violations and Sanctions

Failure to adhere to this governance framework may result in disciplinary action up to and including termination of employment, revocation of developer repository access, and external regulatory disclosures in accordance with ISO/IEC 42001 standards.